

Lateral Movement & Privilege Escalation

SOC Analyst Technical Reference Notes

Lateral Movement

What is Lateral Movement?

Lateral Movement is when an attacker moves from one compromised system to other systems inside a network. Instead of leaving the network, the attacker moves sideways across machines.

Attackers do this to:

- Find valuable data
- Reach domain controllers
- Access admin accounts
- Deploy ransomware across the network

Typical Attack Path:

Phishing → User Laptop Compromise → Lateral Movement → Domain Controller Full Network Control

Attack Flow Diagram (Step-by-Step)

1. **Research targets** (SNS)
2. **Spear Phishing** (you@gmail.com)
3. **Victim clicks link** unwittingly
4. **Bot installed, back door established** and receives commands from C2 server
5. **Scan LAN** for vulnerable hosts to exploit & find privileged users
6. **Privileged account found**
7. **Data exfiltrated**
8. **System compromised** and data breached

Why Attackers Perform Lateral Movement

Because the first compromised system rarely has valuable data.

Example:

- **Attacker compromises:** Employee Laptop
- **But target is:** File Server, Domain Controller, or Database Server

So, the attacker moves across the network.

Common Lateral Movement Techniques

1. Pass-the-Hash (PtH)

- Attacker steals password hashes from memory.
- Instead of cracking the password, they reuse the hash directly.
- **Example tools:** Mimikatz, CrackMapExec
- **SOC Indicators:** NTLM authentication anomalies, Logins without password usage

2. Pass-the-Ticket (Kerberos Attack)

- Attacker steals Kerberos authentication tickets.
- Then uses them to access other machines.
- **SOC indicators:** Suspicious Kerberos ticket usage, Unusual TGT activity

3. Remote Desktop Protocol (RDP)

- Attacker uses stolen credentials to connect via Port 3389.
- **SOC indicators:** Internal RDP connections, Unusual login locations, Login outside working hours

4. SMB/Windows Admin Shares

- Attacker copies tools across machines using `\\target\C$`.
- **Common tools:** PsExec, Impacket, CrackMapExec
- **SOC indicators:** Admin share access, Suspicious file transfers, Service creation events

5. Windows Management Instrumentation (WMI)

- Allows remote command execution.
- **Example command:** `wmic /node:target process call create "malware.exe"`
- **SOC indicators:** WMI process creation, Remote execution logs

Real SOC Scenario

Alert sequence:

1. Suspicious login to user laptop
2. Mimikatz executed
3. Admin credentials dumped
4. Attacker logs into file server
5. Ransomware deployed

Note: Step 4 is Lateral Movement.

Privilege Escalation

Privilege escalation is when an attacker gains higher permissions than originally allowed.

Example: User account → Administrator access

Two Types of Privilege Escalation:

1. **Vertical Privilege Escalation:** User → Admin (e.g., Normal User → Local Admin → Domain Admin).
2. **Horizontal Privilege Escalation:** User → Another User (e.g., Employee account → Manager account).
Same level but different privileges.

Why Attackers Need Privilege Escalation

Because the initial compromise often gives **Low privilege access**. Attackers want **Administrator / Root / Domain Admin** access, which allows them to:

- Disable security tools
- Dump credentials
- Access servers
- Deploy ransomware

Common Privilege Escalation Techniques

- **Exploiting Software Vulnerabilities:** Outdated Windows kernel or vulnerable drivers. Attacker runs exploit → becomes admin.
- **Credential Dumping:** Tools like Mimikatz or LSASS memory dumping to extract admin passwords.
SOC indicators: LSASS process access, Credential dumping alerts.
- **Misconfigured Permissions:** Service runs as SYSTEM but the executable is writable. Attacker replaces the file → gains admin access.
- **Token Impersonation:** Windows access tokens are stolen from high-privilege processes, allowing the attacker to impersonate the admin.
- **Scheduled Task Abuse:** Attacker modifies scheduled tasks running as admin.

SOC Indicators of Privilege Escalation

Watch for:

- Sudden admin rights assignment
- New admin account creation
- Service creation events
- Suspicious LSASS access
- Privilege escalation exploits

Important Windows Event IDs:

Event ID	Meaning
4672	Special privileges assigned
4688	Process creation
4720	User account created
4732	User added to admin group

Attack Chain (Real Ransomware Scenario):

Phishing Email → User Laptop Compromise → Credential Dumping → Privilege Escalation → Lateral Movement → Domain Controller Access → Ransomware Deployment

Difference Between Lateral Movement & Privilege Escalation

Feature	Lateral Movement	Privilege Escalation
Goal	Move across systems	Gain higher permissions
Direction	Sideways	Upwards
Example	Laptop → Server	User → Admin
Purpose	Expand access	Gain control

SOC L1 Thinking Task & Answer

Task:

Suppose you see this sequence in logs:

1. User laptop executes Mimikatz
2. LSASS memory accessed
3. Admin login occurs from that machine
4. RDP connection to file server

Which stages occurred here?

Answer:

Step	Activity	Stage
1	Mimikatz executed	Credential Dumping
2	LSASS accessed	Credential Dumping
3	Admin login occurs	Privilege Escalation
4	RDP to file server	Lateral Movement

The final stages sequence is: Credential Dumping → Privilege Escalation → Lateral Movement.